

Data Leak Risk Analysis

Data flow, exposure scenarios, least privilege, DLP, encryption, and response controls

Scenario

A representative organization handles customer contact information, transaction records, internal financial documents, employee data, and authentication-related information across email, endpoints, SaaS tools, cloud storage, and databases.

Data Flow & Exposure Review

Data / flow	Primary risk	Preventive controls	Detective controls	Response
Customer records: app -> database	Unauthorized query/export	RBAC, service least privilege, encryption, secure coding	DB audit logs, unusual query/export alerts	Revoke access, preserve logs, scope records, investigate
Files: employee -> cloud storage	Public/overbroad sharing	Private defaults, classification, sharing restrictions	DLP/CSPM alerts, access logs	Remove sharing, rotate links, review downloads
Email: user -> external recipient	Misdirected or intentional disclosure	DLP rules, recipient warnings, encryption	Outbound DLP events, mailbox audit	Recall/block where possible, classify incident, notify stakeholders
Endpoint -> removable media	Local data exfiltration	Device control, least privilege, encryption	EDR/device events, DLP	Isolate device, preserve evidence, investigate user intent
Admin -> sensitive systems	Privileged misuse	PAM, MFA, separate admin accounts	Privileged-session/admin logs	Disable account, preserve logs, perform access review

Control Plan

- **Least privilege:** Restrict access to business need; recertify sensitive-data and privileged roles; remove obsolete permissions.
- **Data classification:** Define Public, Internal, Confidential, and Restricted handling rules; label sensitive repositories where feasible.
- **Encryption:** Protect sensitive data in transit and at rest using approved cryptography and managed key practices.
- **DLP:** Monitor high-risk outbound channels and tune rules to business context to reduce false positives.
- **Logging:** Retain authentication, sharing, export, administrative, and DLP events in centralized monitoring.
- **Training:** Reinforce secure sharing, phishing awareness, approved storage, and prompt incident reporting.

NIST SP 800-53 Example Mapping

Control family / example	Application
AC - Access Control / AC-6 Least Privilege	Restrict user, admin, and service-account permissions.
AU - Audit & Accountability	Log sensitive access, exports, sharing, and administrative events.
MP - Media Protection	Control removable media and sensitive-data handling.
SC - System & Communications Protection	Encrypt data in transit and at rest where required.
SI - System & Information Integrity	Detect suspicious activity and respond to indicators of compromise.
IR - Incident Response	Triage, contain, investigate, document, and recover from leakage events.

Incident Decision Criteria

- Data classification and sensitivity; number of records; recipient or destination; evidence of access/download; legal or contractual obligations; continuing exposure; and ability to contain.
- Do not label an event a breach until facts support that conclusion; preserve evidence and involve legal/privacy stakeholders where required.